

小南核心考点总结

核心功能与考点

ハッシュ関数の不可逆性

只能从明文算哈希，无法从哈希反推明文。

プレースホルダ (Placeholder)

防御 SQL 注入的根本手段（参数与 SQL 指令分离编译）。

多層防御 (Defense-in-depth)

不把鸡蛋放在一个篮子里，设置多重防御机制。

ソルト (Salt)

解决“相同密码产生相同哈希”的问题（保存在 DB 内）。

ペッパー (Pepper)

解决“DB 被拖库后防御失效”的问题（保存在 DB 外部的服务器安全区）。

ストレッチング (Stretching)

多次循环哈希，故意增加单次计算耗时，大幅拖慢黑客暴力破解速度。

次の問 1 は必須問題です。必ず解答してください。

問 1 Web サイトのセキュリティに関する次の記述を読んで、設問に答えよ。

F 社は、日用雑貨を製造・販売する中堅企業である。このたび、販路拡大を目的として自社製品を販売する Web サイト（以下、本システムという）を新規に開発した。本システムは、D 社クラウドサービス上に構築しており、Web サーバとデータベース（以下、DB という）サーバから成り、D 社クラウドサービスが提供するファイアウォール（以下、FW という）及び Web アプリケーションファイアウォール（以下、WAF という）を経由してインターネットからアクセスされる予定である。

本システムの開発環境のネットワーク構成（抜粋）を図 1 に示す。なお、本システムはリリース前であり、F 社開発環境の特定の IP アドレスからだけアクセスできるように FW で制限している。

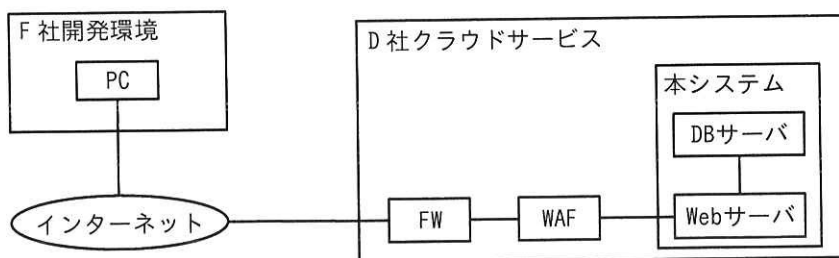


図 1 本システムの開発環境のネットワーク構成（抜粋）

本システムの主な仕様を次に示す。

- ・会員登録時に自動で発行される会員番号と会員が設定したパスワードをログインフォームに入力してログインする。商品の購入はログイン後に行う。
- ・パスワードとして使用できる文字は、英数字に一部の記号を加えた 70 種類である。
- ・パスワードは、6 字以上 16 字以下で設定する。
- ・会員テーブルは、会員番号、メールアドレス、パスワードのハッシュ値、姓、名、住所、電話番号の 7 フィールドで構成されている。①パスワードのハッシュ値は、会員が設定したパスワードをハッシュ関数によってハッシュ化したものである。

F 社情報セキュリティ部の G 部長は、本システムのリリース前にペネトレーションテストを実施することを決定し、H 主任をリーダーに任命した。H 主任は、セキュリ

■ 事背景速 览（1分钟看懂发生了什么）

公司背景：F 公司开了一套商网站，部署在 D 公司的云上，包含 Web 服务器和数据库（DB）服务器，外面套了防火（FW）和 WAF（Web应用防火墙）。

发布前测试：F 公司了渗透测试公司 U 来做“黑客模拟攻击”。为了测试后端防御，他们把 WAF 改成了“只记录日志、不拦截攻击”的模式。

黑客得手了！测试人员通过以下 3 步成功黑入系：

利用 SQL注入漏洞 拖出了数据库里的所有会员表数据（包括密码的哈希值）。

利用 彩虹表（Rainbow Table）逆向推导出了部分用户的明文密码。

用猜出的密码伪装成会员成功登录。

接下来，我们要帮 F 公司的负责人 H 主任分析漏洞原因并制定防护对策。

設問 1：哈希存储的特性

题目设问

针对正文下划线①，将用户的密码通过哈希函数计算后保存，对于防范信息泄露威胁有什么好处？这是利用了哈希值的什么特性？（25字以内）

标准答案：ハッシュ値からパスワードの割出しは難しい

直接说一方向性也可以

ティベンダーである U 社に本システムのペネトレーションテストの実施を依頼した。
ペネトレーションテストは、U 社内の PC からインターネット、FW 及び WAF を経由して本システムにアクセスする経路で実施した。

- ペネトレーションテスト期間中は、FW 及び WAF に対して次の変更を行った。
- ・FW に対する変更
通信を許可するアクセス元 IP アドレスとして、ペネトレーションテストに用いる U 社の IP アドレスを追加する。
 - ・WAF に対する変更
攻撃を検知した際には、通信の遮断は行わず、検知したことだけを記録する。

- 〔ペネトレーションテストの結果〕
- ペネトレーションテストの結果、次の手順（以下、本シナリオという）で会員のパスワードが推測されて、不正にアクセスされてしまうことが確認された。
1. ②SQL インジェクション攻撃によって会員テーブルのデータを取得する。このとき取得した会員テーブルのデータ（抜粋）を表 1 に示す。
 2. レインボーテーブル攻撃によって、手順 1 で取得した会員テーブル中のパスワードのハッシュ値から元のパスワードを推測する。
 3. 推測したパスワードを利用して、会員になりすまして本システムにログインする。

表 1 取得した会員テーブルのデータ（抜粋）

会員番号	パスワードのハッシュ値	姓	名
21717202	5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a11ef721d1542d8	T 中	T 郎
21717203	2597a7caf656e89e9ab35e12326d557ebfe9b7b5dcbe4c564e74070fa5cfcbe5	S 藤	H 子
30781985	5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a11ef721d1542d8	S 藤	J 郎
36150833	ac9689e2272427085e35b9d3e3e8bed88cb3434828b43b86fc0596cad4c6e270	S 木	H 子
45905900	ac9689e2272427085e35b9d3e3e8bed88cb3434828b43b86fc0596cad4c6e270	Y 田	J 郎
45917046	d82494f05d6917ba02f7aaa29689ccb444bb73f20380876cb05d1f37537b7892	T 中	T 郎

稼働中のシステムのログインフォームに対してパスワードを総当たりで試行する a 攻撃では、システム側で試行回数に制限を設けて対策することができるが、レインボーテーブル攻撃ではそれができない。

H 主任は、本システムの修正方針を整理するために、SQL インジェクション攻撃及

针对正文下划线 ②，会员表数据遭到泄露，直接侵害了信息安全三要素中的哪一个？（汉字3字）
标准答案：機密性

- 机密性（Confidentiality）
只有该看的人才能看（防泄露）
✓ 会员隐私数据被偷看、泄露
完整性（Integrity）
数据不能被随心所欲乱改（防篡改）
数据被黑客篡改、删库
可用性（Availability）
想用的时候随时能用（防瘫痪）
网站被 DDoS 攻击打瘫痪打不开

填空 [a]：为什么是暴力破解？
题目提到：“在登录界面逐个尝试密码的 [a] 攻击，可以通过限制尝试次数（如输错5次锁账号）来防御”。
这种挨个尝试所有字符组合的穷举攻击，就叫做 暴力破解攻击（Brute Force / ブルートフォース）。

びレインボーテーブル攻撃への対策を検討することにした。なお、ペネトレーションテスト期間中に WAF で SQL インジェクション攻撃が検知できていたが、③仮に対策の一つが破られても他の対策で攻撃を防ぐという考え方に基づき、攻撃への対策を WAF だけに頼らず本システム自体でも行うことにした。

针对正文下划线③，“即使某一道防线被突破，也要靠其他防线阻止攻击”的思考方式叫什么？（汉字4字）

标准答案：多層防御（纵深防御 / 多层防护）

〔SQL インジェクション攻撃への対策の検討〕

本システムのソースコードを調査したところ、一部の処理で外部からの入力値をそのまま SQL 文に埋め込んでいる箇所が存在していた。そこで、対策として、b を利用する方式を採用することにした。この方式では、外部からの入力値が埋め込まれる箇所を専用の記号に置き換えた SQL 文の雛形をあらかじめ作成しておき、専用の記号で置き換えた箇所に DB 管理システム側で外部からの入力値を割り当てる。

填空 [b]：为什么是占位符 (Placeholder) ？

漏洞代码（字符串直接拼接）：

```
SQL-- 黑客在输入框输入：' OR '1'='1
SELECT * FROM users WHERE user_id = '' OR '1'='1'
-- 导致恒真条件成立，全部数据被拖库！
```

正确防御方案（占位符 / 预编译）：
SQL-- 先用特殊的符号（如 ? 或 \$1）占位，生成模板
SELECT * FROM users WHERE user_id = ?

〔レインボーテーブル攻撃への対策の検討〕

本システムでは会員のパスワードをハッシュ化して保存しているが、パスワードそのものにハッシュ関数を 1 回適用しただけであったので、レインボーテーブル攻撃に対して脆弱であった。そこで、パスワードをハッシュ化する際に、次の三つの処理を組み合わせることにした。

1. ソルトを用いた処理

- ・パスワードをハッシュ化する際に、ソルトを付加した上でハッシュ化する。
- ・ソルトとして、会員ごとに異なるランダムな文字列を用意し、会員テーブルに格納する。

2. ④ペッパーを用いた処理

- ・パスワードをハッシュ化する際に、ペッパーを付加した上でハッシュ化する。
- ・ペッパーとして、全ての会員に共通のランダムな文字列を用意し、Web サーバ内の外部からアクセスできない安全な領域に格納する。

3. ストレッチング

- ・ハッシュ関数を複数回適用する。

さらに、ハッシュ化処理の変更に加えて、会員が設定可能なパスワード長を 10 字

以上 64 字以下に変更した。本システムにおいて、パスワード長が 10 字の場合、6 字の場合と比べてパスワードとして使用可能な文字列のパターン数が c 倍になるのでレインボーテーブル攻撃がより困難になる。

H 主任は、これらの対策を取りまとめて G 部長に報告し、承認された。

設問 1 本文中の下線①について、会員のパスワードをハッシュ関数でハッシュ化して保存することは、情報漏えいの脅威に対してメリットがある。それは、ハッシュ値にどのような特性があるからか。25 字以内で答えよ。

設問 2 本文中の下線②について、会員テーブルのデータが漏えいした場合、情報セキュリティの 3 要素のどれが直接的に侵害されたといえるか。漢字 3 字で答えよ。

設問 3 本文中の a，b に入れる適切な字句を解答群の中から選び、記号で答えよ。

解答群

ア エスケープ	イ 許可リスト	ウ サニタイズ
エ 中間者	オ ブルートフォース	カ プレースホルダ
キ リプレイ		

設問 4 本シナリオによって、表 1 に示す会員テーブルのデータが窃取され、会員番号“21717202”の会員のパスワードが推測され不正アクセスを受けたとすると、推測されたパスワードを利用して不正アクセスを受けるおそれが最も強い他の会員は誰か。該当する会員の会員番号を解答群の中から選び、記号で答えよ。

解答群

ア 21717203	イ 30781985	ウ 36150833
エ 45905900	オ 45917046	

設問 5 本文中の下線③の考え方を、漢字 4 字で答えよ。

設問 6 〔レインボーテーブル攻撃への対策の検討〕について答えよ。

(1) 本文中の下線④について、ペッパーを付加してハッシュ化することで本シナリオにおいてレインボーテーブル攻撃が困難になる理由を、ソルトを用いた処理との違いに着目して 35 字以内で答えよ。

(2) 本文中の c に入れる適切な数を、 x^y のような指数を用いた表記で答えよ。

Cは 70^4

标准答案：イ（会员编号：30781985）

原因：因为系统没有加盐，相同的明文密码经过哈希计算后，生成的哈希值必定一模一样（确定性）。

既然 21717202 和 30781985 的哈希值完全一样，说明他们俩设置的密码是完全相同的！黑客只要解开了前者的密码，直接拿去登录后者的账号就行了。

标准答案：会员テーブルの窃取だけではペッパーを得ることができないから（仅窃取会员表是无法获得胡椒值的 / 28字）

加盐（Salt）：

为每个会员生成一个随机字符串拼在密码后面。

△ 致命伤：Salt 是存放在数据库会员表里的。黑客通过 SQL 注入拖库时，会连同 Salt 一起偷走。

加胡椒（Pepper）：

全局共享的密钥，保存在 Web 服务器的独立安全配置文件/环境变量中，绝对不进数据库。

黑客通过 SQL 注入只能拿到数据库的数据，根本碰不到 Web 服务器的文件系统，因此拿不到 Pepper，彩虹表攻击彻底失效！